

基于本体的网络威胁情报分析技术研究

高 见^{1,2}, 王 安¹

1. 中国人民公安大学, 北京 100038

2. 安全防范与风险评估公安部重点实验室, 北京 102623

摘 要:网络安全领域中威胁情报的描述方式多种多样, 迫切需要一种对威胁情报格式化描述的标准, 将非格式化情报信息, 转化为格式化数据, 为情报的可视化知识图谱提供支撑。针对 STIX 2.0 的描述规范, 提取了适应于网络安全威胁情报中的本体元素, 构建了一个可共享、重用、扩展的威胁情报本体模型, 并对领域本体、应用本体和原子本体进行了详细分类。将该模型应用在 Poisonivy 攻击事件中, 提取了 Poisonivy 研究报告中的 61 个实体, 102 个关系, 并将抽取的格式化数据导入 Gephi 进行可视化表达。通过对威胁情报本体模型的构建, 完成了情报信息从非结构化到结构化的转换, 并使用统一的语法进行描述, 最终以知识图谱的方式来表达情报中重要元素, 可以快速定位网络安全事件中的核心元素及之间关系, 为网络安全分析者和决策者, 提供重要依据。

关键词:威胁情报; 本体; 网络攻击; 知识图谱

文献标志码:A **中图分类号:**TP391 **doi:**10.3778/j.issn.1002-8331.1902-0221

高见, 王安. 基于本体的网络威胁情报分析技术研究. 计算机工程与应用, 2020, 56(11): 112-117.

GAO Jian, WANG An. Research on ontology-based network threat intelligence analysis technology. Computer Engineering and Applications, 2020, 56(11): 112-117.

Research on Ontology-Based Network Threat Intelligence Analysis Technology

GAO Jian^{1,2}, WANG An¹

1. People's Public Security University of China, Beijing 100038, China

2. Key Laboratory of Safety Precautions and Risk Assessment, Ministry of Public Security, Beijing 102623, China

Abstract: Threat intelligence is described in a variety of ways in the field of cyber security, there is an urgent need for a standard for the format description of threat intelligence, which can transform unformatted intelligence information into formatted data to provide support for the visual knowledge graph of intelligence. According to the description specification of STIX 2.0, many ontology elements adapted to network security threat information are extracted, a threat intelligence ontology model that can be shared, reused and extended is constructed, and the domain ontology, application ontology and atomic ontology are classified in detail. Finally, the model is applied in the Poisonivy attack event, and 61 entities and 102 relationships in the Poisonivy research report are extracted, and the extracted formatted data is imported into Gephi for visual expression. Through the construction of the threat intelligence ontology model, the transformation of intelligence information from unstructured to structured is completed, and the unified grammar is used for description. Finally, the important elements in the intelligence are expressed in the way of knowledge graph, and the network security event can be quickly located. The core elements and relationships between them provide an important basis for network security analysts and decision makers.

Key words: threat intelligence; ontology; cyber attacks; knowledge graph

基金项目:国家重点研发计划(No.2017YFC0820606); 中国人民公安大学中央基本科研业务费项目(No.2019JKF218)。

作者简介:高见(1982—), 男, 博士, 讲师, 研究领域为网络攻防, 网络犯罪, 僵尸网络, E-mail: gaojian@ppsuc.edu.cn; 王安, 男, 研究生, 研究领域为网络安全。

收稿日期:2019-02-27 **修回日期:**2019-04-04 **文章编号:**1002-8331(2020)11-0112-06

CNKI 网络出版:2019-06-14, <http://kns.cnki.net/kcms/detail/11.2127.tp.20190613.0917.004.html>

1 引言

近些年来,网络安全事件不断发生,网络攻击的形式复杂多变,检测和预测这些动态类型的攻击是一项充满挑战的任务。在当前的许多领域中,对于知识图谱的研究已经非常成熟,本文将知识图谱与威胁情报结合在一起构建网络安全事件的知识库。通过对开源情报的分析,收集和分析结构化数据和非结构化数据来获取相关信息,抽取威胁情报中的本体元素,完成网络安全事件的分析及事件过程中涉及攻击工具、漏洞、攻击方法等元素的关系。

在网络安全领域中,已经有大量的基础研究,构建相关的知识库。例如,MITRE 公司对漏洞数据库进行了统一的描述,每个漏洞具有统一 ID、威胁等级、威胁类型等基本信息。除此之外,杀毒软件供应商依据其掌握的大量样本库,建立了有关恶意软件的病毒特征库。威胁情报大量来自互联网^[1],互联网中报道了大量的网络攻击事件、网络攻击工具等重要信息,如一些安全博客、安全内参、黑客论坛等。学术界同样对网络威胁情报的分析和表示进行了大量的研究,贾焰等人^[1]提出了一种构建网络安全知识图谱的实用方法,该文中使用了 Stanford 的 NER 来训练提取器,利用提取器抽取获取信息中的网络安全本体。王若佳等人^[2]提出了一种基于知识图谱的国际和国内竞争情报对比的方法,在 Web of Science 数据库和 CSSCI 数据库两个文献数据库中,从研究热点、知识基础和演化发展三个角度进行了对比,最后用 Citespace 软件对其生成的知识图谱进行了可视化绘制。王通等人^[3]研究了一种基于深度学习的威胁情报知识图谱构建技术,利用监督性的深度学习模型,通过对威胁情报的实体及其关系进行抽取,最后通过图数据库完成了知识图谱的可视化。

使用知识图谱对网络威胁情报进行分析,主要难点有两个:一是对网络威胁情报中本体的定义以及知识抽取;二是通过已抽取的知识进行推演,学习到新的知识。在对知识的抽取中,因为大量的信息来自网站的网络安全报道和安全企业的安全分析报告,抽取的准确率难以达到对知识表达的要求。本文将通过威胁情报标准化的描述语言,对威胁情报进行结构化处理,提高威胁情报中知识实体抽取的准确率,并将所有这些与安全相关的知识按照一定的规则关联在一起,对入侵检测和网络安全态势感知的相关工作有很重要的意义。

2 威胁情报标准化描述

威胁情报输出的多样化,导致对情报分析和抽取过程中效率和准确率大大降低,影响了一些模型和算法对威胁情报的分析结果。因此,威胁情报的共享需要一整套描述标准和规范,通过对威胁情报的描述、处理可以通过格式化的语言进行表达,并直接实现情报共享,实

现“未攻先防”的动态防御效果。目前成熟的国外威胁情报标准包括网络可观察表达式(CyboX)、结构化威胁信息表达式(STIX)以及指标信息的可信自动化交换(TAXII)等。

2.1 CyboX

CyboX 全称为 Cyber Observable eXpression(网络可观察表达式)^[4],它是一种用于编码和传输有关网络可观测的高保真信息的标准化语言。在 CyboX 之前,没有统一的标准机制用于指定、采集、描述或交流这些网络的可观察表达。每个机构通常具有自己独特的表示方法。这使得观察的一致性、效率和总体态势感知变得困难。CyboX 解决这些问题。其可观察的对象包括了事件或状态属性,如注册表键值,删除文件,或收到一个 http 请求。通过规范一套具体的标准,使得这些行为或属性可以被分析。

2.2 STIX

STIX 全称为 Structured Threat Information eXpression(结构化威胁信息表达式)^[5],它是一种用来描述网络威胁信息的结构化语言,可以以一致的方式共享,存储和分析。STIX 由一些关键结构组成,它们的含义与内容如下:

观测表征:描述已经或可能出现在网络中的事物;

特征指标:描述模式可能会看到什么,以及它们的含义是什么;

安全事件:描述特定的角色操作的实例;

方法与流程:描述某一角色实施攻击的模式,工具,基础设施,目标受害者,和其他的一些手段与方法;

利用目标:描述漏洞,可能被利用的弱点或配置;

响应措施:描述反应为了应对攻击或作为预防措施可能采取的行动;

组织运动:描述一系列事件或意图;

威胁源:对威胁人员的鉴别与描述;

安全报告:收集 STIX 相关内容和给它们共享。

2.3 TAXII

TAXII 全称为 Trusted Automated eXchange of Indicator Information(指标信息的可信自动化交换)^[6],它是一个自由和开放的传输机制,用于规范网络威胁的自动交换信息。TAXII 旨在整合与现有的共享协议,包括访问控制的局限性。TAXII 不是一个特定的信息共享协议,它不定义协议或者非技术方面的信息共享网络威胁。相反,TAXII 使维护组织能够很容易地共享他们选择的合作伙伴选择的信息,同时利用现有关系和系统。通过使用 TAXII,可以以一个安全的、自动化的方式来分享 STIX 内容。

3 本体模型构建

本体(Ontology)^[7]是一个基于逻辑、语义丰富的形

式化模型,是对某个领域内共享知识的形式化规范描述^[8]。目前,被普遍认同的定义是Studer等人^[9]提出的“本体形式化规范说明”。通过对领域内知识进行规范化描述并建立知识库^[9],创建概念与概念、个体与个体、概念与个体之间的关系,用本体来描述知识库,并用来完成推理、查询和关系可视化等功能。

STIX 1.0中定义了8种对象,分别是:Incident(安全事件)、Observable(观测表征)、Indicator(特征指标)、Course of Action(响应措施)、Threat Actor(威胁源)、Campaign(组织运动)、TTP和Exploit Target(攻击目标)。STIX 2.0^[10]将1.0版本中的TTP与Exploit Target拆分为Attack Pattern(攻击模式)、Malware(恶意代码)、Tool(攻击工具)、Vulnerability(漏洞);删去了Incident;新增了Report(安全报告)、Identity(身份)、Intrusion Set(入侵集合),共12个对象。

3.1 威胁情报领域本体

威胁情报领域本体可以用来描述威胁情报中的本体及其关系,并对该领域的本体概念及其特征和规律给出一种形式化描述。图1中采用LCG(Language Concept Graph)描述了威胁情报报的本体结构。LCG是一种有向图,图中椭圆代表本体概念,有向边代表本体之间的关系。本文中对威胁情报领域本体分为6类:攻击目标、攻击者、漏洞、TTP、观测指标和防御措施。本文中对威胁情报领域本体分为6类对攻击事件进行描述,相较于Stix2.0,增加了攻击目标和TTP;保留了Indicator, Course of Action, Threat Actor和Vulnerability,分别对应观测指标,防御措施,攻击者和漏洞;其中TTP中包含了传统的攻击模式、攻击工具和攻击过程三个部分。

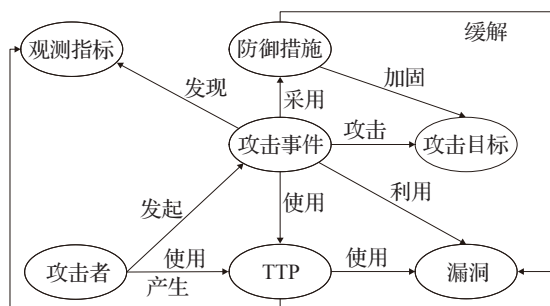


图1 基于STIX2.0的威胁情报本体关系图

3.2 威胁情报应用本体

威胁情报的应用本体是对领域本体的细化描述,根据以上的分类结果,对领域本体的描述及应用本体的分类如图2所示。

(1)攻击目标,是指攻击者在攻击过程中选择的具体目标,应用本体种包含了硬件、链路、服务和数据四个子类。

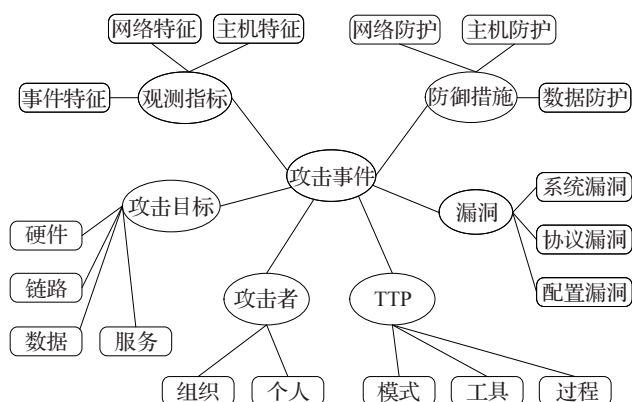


图2 威胁情报应用本体

(2)攻击者,是指在发起攻击的组织或个人,应用本体种将其分为:政府组织、民间团体和个人。

(3)漏洞,是指在攻击过程中使用到的未公开漏洞和已公开漏洞,通常按照国际通用漏洞编号进行统一命名,其中包括:系统漏洞、协议漏洞、配置漏洞。

(4)TTP,概念来自于军事领域及反恐活动,现被信息安全领域用来描述攻击过程中的战术、技术和攻击过程。按照其原始内涵进行分类,TTP包含攻击模式、攻击工具和攻击过程三个子类。

(5)防御措施,是指在预防攻击或网络攻击事后加固时,采取的安全保护措施。其中包括:网络防护、本地防护和数据防护。

(6)观测指标,是指在网络攻击过程中产生的威胁情报指标。按照其类型分为:网络特征、主机特征和事件特征。

3.3 威胁情报原子本体

威胁情报中的原子本体可以直接实例化图谱中的实体,同时原子本体和应用本体之间是类和实例的关系。原子本体在本体中是最小的不可分割的概念,因漏洞和攻击者没不可再分,所以没有原子本体。

(1)攻击目标原子本体

攻击目标原子本体,是指网络攻击的目标,本文中按照其类型分为:硬件、链路、服务和数据,如图3所示。硬件中包含安全设备^[11-12],如IDS、防火墙,交换设备,如交换机、路由器;工控设备,如PLC;主机设备,如CPU、BIOS。以链路为攻击目标,本文将其分为影响链路功能和影响链路性能两类。面向服务的攻击可分为系统服务和应用服务,如smb是操作系统的服务,永恒之蓝便是利用该服务漏洞进行攻击,而Web漏洞是应用服务,SQL注入,XSS等都是针对Web服务进行的攻击方式。以数据为目标的攻击,分为系统数据和应用数据,一些攻击是以获取系统数据为目的,如进程列表、服务列表、系统密码文件等,属于以系统数据为攻击目标的类型,一些攻击是以获取应用数据为目的,如DOC文档、数据库内容等,属于以应用数据为攻击目标的类型。

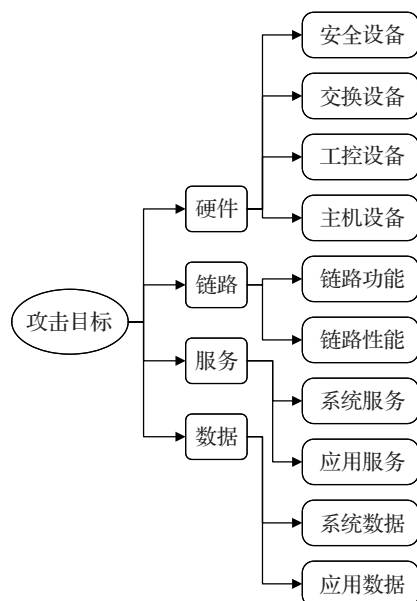


图3 攻击目标原子本体

(2) TTP原子本体

TTP原子本体是攻击方所涉及元素,其中包括攻击模式、攻击工具和攻击过程。在攻击模式中,采用CAPEC^[13]对攻击模式的分类,攻击模式枚举与分类(CAPEC)网站由Mitre公司托管,是安全专业人士用来理解攻击的分类体系。攻击模式中分为信息收集、概论攻击、突破访问控制、欺骗攻击、滥用攻击、操控数据和操控系统资源。在攻击过程中,本文采用洛克希德·马丁公司提出的Cyber Kill Chain模型^[14],将其分为:侦查跟踪、武器构建、载荷投递、突破利用、安装植入、通信控制和达成目标,如图4所示。将攻击按照其类别分为:提权类、拒绝服务类、信息收集类和驻留类。

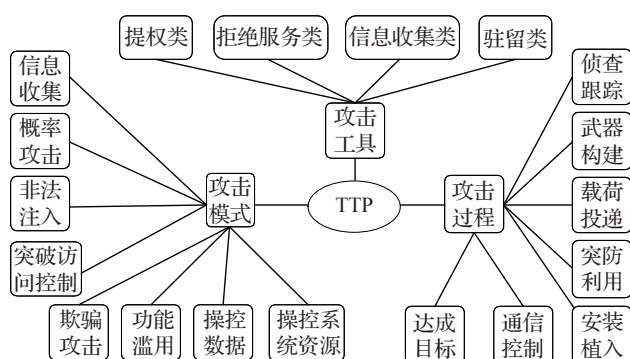


图4 TTP原子本体

(3) 防御措施原子本体

防御措施原子本体是根据遭受的攻击所采取的响应措施,本文分为三个方面:网络防护、本地防护和数据防护,如图5所示。网络防护,是在预防或遭受攻击时,网络传输过程采取的安全防护,如:防火墙、IDS、安全审计设备、网闸等。本地防护,是在客户端或服务端上进行的防护措施,如:操作系统的安全配置,杀毒软件和本地防火墙以及应用的安全配置。数据防护,是针对数据

本身进行的防护措施,随着隐私数据泄露的事件增加,数据的防护显得尤为重要。本文中将其分为加密传输、加密存储和备份恢复。

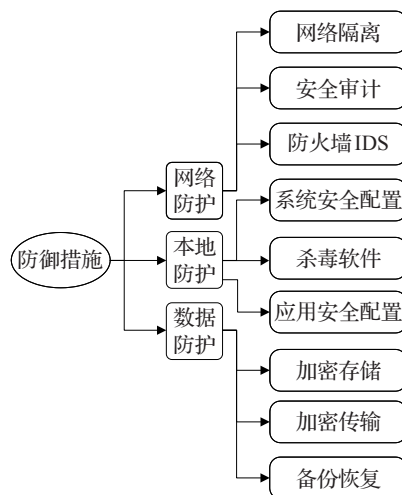


图5 防御措施原子本体

(4) 观测指标原子本体

观测指标的原子本体主要分为主机特征和网络特征两个部分,用来描述威胁情报中的可观测指标,如图6所示。主机特征中,如:恶意软件释放的路径信息、新增的注册表项信息、系统中建立的互斥体信息以及样本的哈希值。网络特征中,如:连接的IP地址信息、域名信息、端口信息和使用协议等。

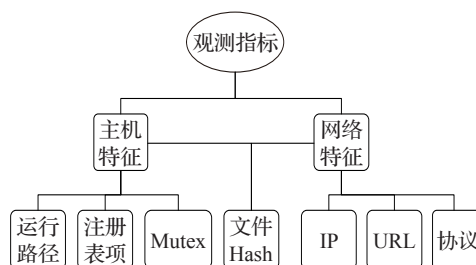


图6 观测指标原子本体

4 威胁情报的知识图谱示例

为了清晰地描述网络威胁情报的知识图谱表达方式,本章将采用结构化信息标准促进组织(oasis)公布的依据STIX2.0标准生成的威胁情报^[15],主要对Poison Ivy进行分析。Poison Ivy本质上是一款木马程序(RAT),攻击者可利用它控制目标系统。Poison Ivy木马生成器从1.0.0版本开始有几十个版本,该工具可以生成EXE和shellcode。本次分析中,将FireEye对Poison Ivy的研究报告按照STIX2.0标准的JSON格式转化为csv格式,并将数据导入Gephi对实体和关系进行表示,其中包含实体共61个,关系102个,如图7所示。

本次的攻击活动主要涉及了恶意代码、攻击模式和漏洞信息等6种实体,相应的统计个数如表1所示。

因malware数量多,且都是同一木马病毒的变种,

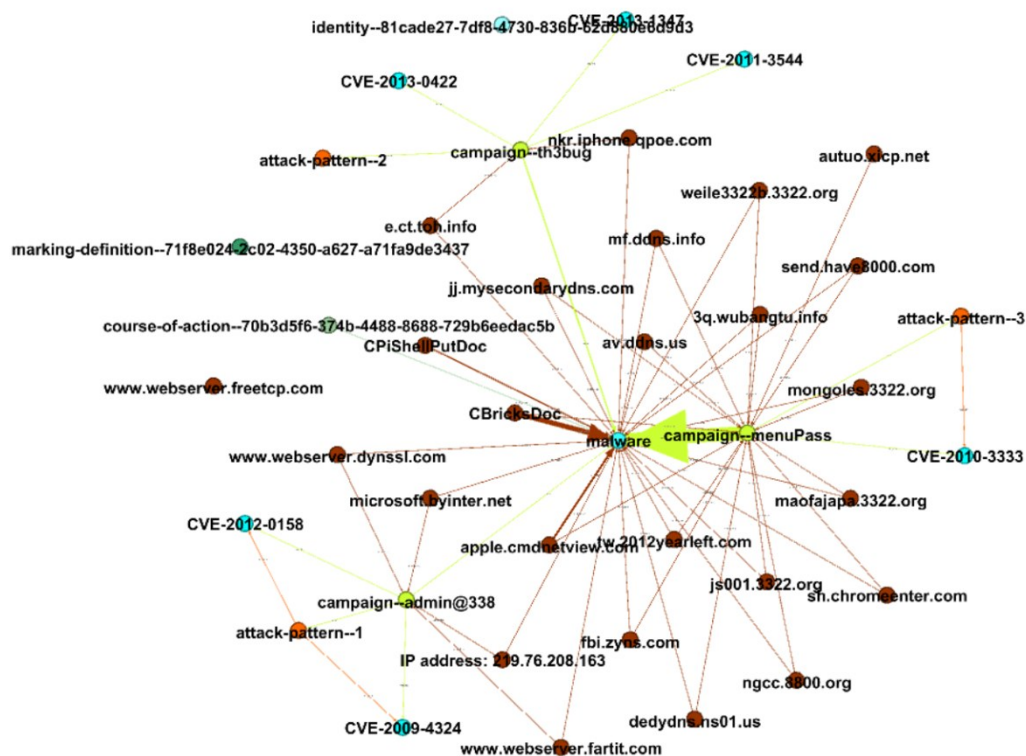


图8 Poisonivy实体关系处理后图谱

对该模型进行了验证,通过图谱的表达,可以更加直观地了解攻击事件中的重要实体及其之间的关系。要想真正准确地表达威胁情报的内容,实现威胁情报的精准可视化,需要尽快建立一个对威胁情报描述的规范体系,只有这样才能从不同的情报源中提取知识实体,为之后的数据分析和预测提供数据来源。

参考文献:

- [1] 贾焰,亓玉璐,尚怀军,等.一种构建网络安全知识图谱的实用方法[J].Engineering,2018,4(1):117-133.
- [2] 王若佳,李颖.基于知识图谱的国际和国内竞争情报对比研究[J].情报杂志,2016,35(1).
- [3] 王通,艾中良,张先国.基于深度学习的威胁情报知识图谱构建技术[J].计算机与现代化,2018(12):21-26.
- [4] Casey E,Back G,Barnum S.Leveraging CybOX to standardize representation and exchange of digital forensic information[J].Digital Investigation,2015,12:102-110.
- [5] Ussath M,Jaeger D,Cheng F,et al.Pushing the limits of cyber threat intelligence:extending STIX to support complex patterns[C]//Information Technology:New Generations,2016.
- [6] Fransen F,Smulders A,Kerkdijk R.Cyber security information exchange to gain insight into the effects of cyber threats and incidents[J].E&I Elektrotechnik Und Informationstechnik,2015,132(2):106-112.
- [7] Rodriguez G D,Velasco D.Ontologies for network security and future challenges[C]//12th International Conference on Cyber Warfare and Security,2017.
- [8] Simmonds A,Sandilands P,Ekert L.An ontology for network security attacks[C]//Second Asian Applied Computing Conference on Applied Computing,2004.
- [9] Staab S,Studer R.Handbook on ontologies[M]//International handbooks on information systems.Berlin:Springer,2004:227-255.
- [10] STIX 2.0 examples[EB/OL].[2018-05].<https://oasis-open.github.io/cti-documentation/stix/examples.html>.
- [11] 王前,冯亚军,杨兆民,等.基于本体的网络攻击模型及其应用[J].计算机科学,2010,37(6):114-117.
- [12] 李文雄,武东英,刘胜利,等.基于本体的网络攻击案例库模型研究[J].计算机科学,2014,41(10):173-176.
- [13] Yuan X,Nuakoh E B,Beal J S,et al.Retrieving relevant CAPEC attack patterns for secure software development[C]//CISR'14,2014:33-36.
- [14] Yadav T,Mallari R A.Technical aspects of cyber kill chain[C]//Third International Symposium on Security in Computing and Communications(SSCC'15),2015.
- [15] Iannacone M,Bohn S,Nakamura G,et al.Developing an ontology for cyber security knowledge graphs[C]//Proceedings of the 10th Annual Cyber and Information Security Research Conference,2015:1-4.